# GIDFINE — PHASE 3C: WORKFLOW INTEGRATION & SECURITY AUDIT

**Branch:** development | **HEAD:** afb4323 | **Stack:** React 19 + TypeScript + Convex | **Spec:** Gidfine_Dev_Guide.md v1.1

## 1. Executive Summary

Phase 3C independently verified the implementation of the Gidfine loan agency platform across Phases 1, 2, 3A, and 3B. The audit confirmed that the complete 8-step loan workflow is enforced on the server, lender acceptance strictly cannot activate loans or disburse funds, data redaction (borrower PII and agency margins) is enforced at the server query level, and 30/30 Node unit tests, 6/6 Python regression tests, and full production builds succeed with 0 errors.

## 2. End-to-End Workflow & Invariants Verified

| Step | Stage & Action | Actor Role | Server Guard & Invariant Verified |
|---|---|---|---|
| 1 | Application Submission | borrower | Validates positive pesewas/tenure; locks agency tenant boundary; audit logged. |
| 2 | Terms Proposal | agency_admin / officer | Preserves versioning; supersedes pending quotes; sets status to LENDER_PENDING. |
| 3 | Lender Decision | assigned lender | Enforces actorUserId == assignedLenderId; transitions to LENDER_ACCEPTED. |
| 4 | Agency Approval | underwriter | Non-bypass: requires lender acceptance; transitions to AGENCY_APPROVED. |
| 5 | Borrower Consent | borrower | Requires affirmative consent; records Act 843 terms snapshot; transitions to BORROWER_ACCEPTED. |
| 6 | Snapshot Fingerprinting | system | Deterministic SHA-256 fingerprint verified against exact approved terms. |
| 7 | Disbursement Readiness | cashier / officer | Read-only audit: verifies approval, borrower consent, and fingerprint validity. |
| 8 | Payment Lockout | read-only guard | paymentInitiated: false, fundingConfirmed: false, repaymentScheduleActive: false. |

## 3. Security & Data Isolation Audit Findings

• **Access Controls:** Unauthenticated calls rejected across all 8 endpoints. Cross-role tampering and cross-agency queries rejected with 0 leaked records.
• **Server-Side Redaction:** In lender queries, borrower name, phone, email, and identity docs are completely omitted (case reference APP-XXXXXX). Agency margins are hidden from both lender and unapproved borrower views.
• **Anti-Tamper & Invariants:** Stale/duplicate decisions rejected (INVALID_STATE). Bypassing agency approval throws StateTransitionError. All 5 milestone events write immutable auditLogs.

## 4. Test Results Summary

| Test Suite | Passed | Failed | Coverage |
|---|---|---|---|
| E2E Security Audit (e2eSecurityAudit.test.ts) | 2 | 0 | Full 8-step lifecycle, role checks, tenancy isolation, PII & margin redaction. |
| State Machine Guards (stateMachine.test.ts) | 7 | 0 | Linear transitions, assigned lender checks, agency/borrower guards, SHA-256 fingerprint. |
| Convex Mutations & Queries (mutations.test.ts) | 14 | 0 | Auth checks, assigned lender restrictions, PII redaction, accept/decline, duplicate prevention. |
| LoanService Adapter (loanService.test.ts) | 7 | 0 | Pesewas conversions, bps formatting, cloud error throwing, lender queries & decisions. |

| | | | |
|---|---|---|---|
| Python Regression Suite (pytest tests/ -q) | 6 | 0 | All FastAPI loan engine endpoints verified. |
| TypeScript & Production Build | 1845 mods | 0 errors | tsc --noEmit clean; vite build succeeded in 17.03s. |

## 5. Authentication & Cloud Setup (Matthias)

**1. Cloud Deployment:** Execute convex dev / deploy to provision cloud backend and assign VITE_CONVEX_URL.
**2. Auth Provider:** Configure production JWT issuer and JWKS domain in convex/auth.config.ts.
**3. Recommended Next Phase:** Phase 4 (Financial Ledger, dual-authorization cashier disbursement, and repayment allocation).